NIGHTINGALE 72HR BUILD

Nightingale Care Note

A trust-first longitudinal workspace for clinic collaboration

Built by: Qiufeng Wang

Prototype: Synthetic data only • Python + SQLite + browser-native UI

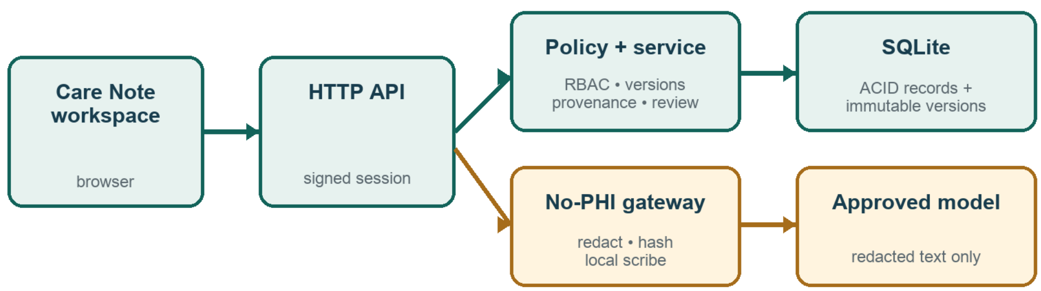
Performance: Authenticated Docker HTTP P95 4.721 ms (target ≤300 ms)

Product thesis

The Care Note is a communication and trust layer beside the EHR - not another shared free-form document. Glance stays at three cards; Review is bounded at seven. A deterministic Consistency Watcher cites both immutable sources, while the Trust Passport requires evidence witnessing before any AI decision. Patient teach-back closes the understanding loop; access transparency and a tamper-evident audit chain make trust inspectable. Role-owned entries preserve authority and never silently merge clinician, staff, patient, or AI claims.

Architecture and request flow

TRUST-CENTRIC REQUEST FLOW



Production swap: OIDC + managed PostgreSQL/KMS; the policy boundary remains unchanged.

- Every API call resolves a short-lived signed actor, then enforces patient binding or clinic scope server-side.
- SQLite supplies ACID writes and optimistic locking in the prototype; the schema maps directly to PostgreSQL/RLS.
- AI text passes only through the visible redaction gateway; the Trust Passport retains source, verification, decision, bounded learning impact, and retention evidence.

Data model and provenance

A highlight is the trust anchor: entry_id + immutable entry_version + character offsets + quote. Resolution verifies the quote against that version. A short-lived evidence token binds actor, version, offsets, and quote digest before a decision is accepted. Verification is likewise an append-only event tied to one exact version, never a mutable timestamp. The same immutable versions power a Time Machine that reconstructs the exact note view and ten-second Glance at any past moment, honestly labelling learned priority and task state as current-only.

Entity	Core fields	Trust role
Entry	patient, role, type, visibility, section, current version	Role-owned timeline unit
EntryVersion	entry, version, content, entities, risk, editor, time	Append-only source snapshot
Comment / Task	entry, assignee, status, completion actor/time	Auditable work without overwrite
Highlight	entry + version + offsets + quote + decision	Exact span-level provenance
Verification / conflict	source version(s), verifier/decision, time	Append-only evidence events
AI note	typed system entry + redaction digest/counts	Distinct, reviewable authority
ImportanceSignal	clinic, feature, bounded weight, evidence	Explainable local learning
TeachBack	instruction version, patient response, coverage, decision	Human-confirmed understanding
AuditLog	metadata + prev_hash + event_hash	Tamper-evident, content-free trace

RBAC, privacy, and concurrency

- Patients are bound to one patient ID and receive only patient-visible instructions; raw AI entries, internal comments, tasks, highlights, and audit data are denied even when a URL is guessed.
- Staff and clinicians edit only role-owned entries. Only clinicians make final AI/conflict/teach-back decisions after witnessing current-version evidence; task transitions require a clinic clinician or assigned/unassigned staff. Patients see content-free viewer metadata, never internal clinical content.
- Every edit carries expected_version inside a write transaction. Different sections save independently; competing writes yield one success and one deterministic HTTP 409 - never last-write-wins loss.

Consistency, review, and AI handling

Consistency rules surface two immutable sources side by side and never diagnose. A source-linked pre-visit brief assembles safety, alerts, work, questions, and changes without creating new clinical conclusions. Review is capped at seven cards with a visible reason and no accept-all. Patient teach-back is bound to one instruction version; deterministic keyword coverage may flag a gap, but only a clinician confirms understanding. AI summaries remain typed system entries; the scribe preview shows raw browser memory versus the exact redacted payload before persistence, and no transcript leaves the machine.

Learning, retention, and operational safety

Explainable importance

Priority combines recency, explicit risk, unresolved work, clinical entities, and clinician authorship. Clinician interaction adjusts clinic-local feature weights, but total learned influence is clamped to ±4.0. The UI exposes used/remaining influence beside base score and rank movement. This is a ranking aid - not a diagnostic model.

Hybrid storage and data decay

- Hot (≤90 days or safety protected): full content indexed for glance and timeline access.
- Warm (91-365 days): structured summary indexed; full immutable version retained.
- Cold (>365 days, low risk): encrypted archive; a provenance stub remains queryable.

The clinician/admin Storage Lens exposes tier, age, protection, and policy for seeded hot/warm/cold history. High-risk, allergy, medication, and safety-net facts are never decayed solely because of age. Physical archival remains an explicit production integration.

Security boundary

prepare_llm_payload removes known/labelled names, Singapore NRIC/FIN or labelled identifiers, and Singapore phone formats before any adapter can receive text. A no-persistence preview shows raw browser memory beside the exact redacted payload, counts, and digest. Content-free audit metadata is canonicalized into a per-clinic SHA-256 chain. A safe local sandbox demonstrates six blocked policy probes without scanning any external system. Production still requires managed ingress, PostgreSQL/object encryption, KMS keys, backups, retention, and legal hold.

Validation and measured performance

Evidence	Result	Status/target
Automated suite	33/33: RBAC; provenance; review; teach-back; audit chain; retention; time machine	**Pass**
Security tests	Token/chain tamper; patient isolation; PHI preview; six safe local probes	**Pass**
Service benchmark	300 reads after 20 warm-ups; median 6.249 ms; P95 6.622 ms	**≤300 ms**
HTTP benchmark	300 Docker reads; signed session + RBAC + SQLite + JSON; median 3.575 ms; P95 4.721 ms	**≤300 ms**

Measurement scope: the HTTP figure includes local transport, signed-session verification, RBAC, SQLite, and JSON; browser rendering and production network still require deployed tracing/load tests.

Assumptions and deliberate trade-offs

The 72-hour build prioritizes the trust-critical collaboration path end to end. Deferred: production OIDC, live EHR/FHIR exchange, PostgreSQL RLS, CRDT rich text, terminology services, managed KMS/retention controls, and ambient voice diarization. These require clinical, security, and operational validation and are not represented as complete.